

API-CONTRACT-001 — Auth API

Version : V1

Statut : MVP

1. Mission

L'Auth API est responsable de l'authentification et de la gestion des sessions des utilisateurs de Vitala.

Elle constitue le point d'entrée sécurisé de la plateforme.

Son objectif est de permettre à un utilisateur de prouver son identité avant d'accéder aux fonctionnalités de Vitala.

L'Auth API ne gère ni les informations de profil ni l'Unified Digital Identity (UDI). Elle fournit uniquement une identité authentifiée qui sera utilisée par les autres domaines.

2. Responsabilités

L'Auth API est responsable de :

- créer un compte utilisateur ;
- authentifier un utilisateur ;
- terminer une session (déconnexion) ;
- renouveler une session ;
- réinitialiser un mot de passe ;
- vérifier une adresse e-mail ;
- gérer les méthodes d'authentification ;
- exposer l'identité authentifiée aux autres domaines.

Elle n'est jamais responsable du Trust, du profil, des préférences ou des données métier.

3. Capacités

L'API fournit les capacités suivantes :

- inscription ;
- connexion ;
- déconnexion ;
- récupération de mot de passe ;
- changement de mot de passe ;
- vérification d'e-mail ;

- rafraîchissement de session ;
 - consultation de la session courante.
-

4. Objets métier

User Identity

Représente l'identité authentifiée de l'utilisateur.

Attributs principaux :

- userId
- email
- authenticationProvider
- emailVerified
- accountStatus
- createdAt
- lastLoginAt

Session

Représente une session active.

Attributs principaux :

- sessionId
 - accessToken
 - refreshToken
 - expiresAt
 - device
 - createdAt
-

5. Flux métier

Inscription

1. Création du compte.
2. Vérification des données.
3. Création de l'identité authentifiée.
4. Envoi d'un e-mail de validation.
5. Initialisation de l'Unified Digital Identity (UDI).
6. Ouverture de la première session après validation.

Connexion

1. Vérification des identifiants.

2. Création ou renouvellement de la session.
3. Retour des jetons de session.
4. Chargement des informations minimales nécessaires aux autres API.

Déconnexion

1. Invalidation de la session.
2. Révocation des jetons.
3. Notification des clients.

6. Contrat REST

Endpoints principaux :

- POST /auth/register
- POST /auth/login
- POST /auth/logout
- POST /auth/refresh
- POST /auth/forgot-password
- POST /auth/reset-password
- POST /auth/verify-email
- GET /auth/session

Toutes les réponses suivent le format standard des API Vitala.

7. Validation

Les règles de validation incluent notamment :

- unicité de l'adresse e-mail ;
- mot de passe conforme à la politique de sécurité ;
- vérification des champs obligatoires ;
- limitation des tentatives de connexion ;
- validation des jetons de session.

8. Sécurité

L'Auth API applique les principes suivants :

- authentification sécurisée ;
- gestion des sessions ;
- rotation des jetons ;
- protection contre les attaques par force brute ;
- limitation du débit (rate limiting) ;
- journalisation des événements critiques.

Toutes les communications sont chiffrées.

9. Dépendances

L'Auth API dépend de :

- système d'identité (Supabase Auth dans le MVP) ;
- service d'e-mail ;
- système de journalisation.

Elle ne dépend d'aucun domaine métier.

Les autres domaines dépendent d'elle.

10. Événements produits

L'Auth API publie notamment :

- UserRegistered
- EmailVerified
- UserLoggedIn
- UserLoggedOut
- PasswordChanged
- SessionRefreshed

Ces événements pourront être utilisés par les moteurs ou les futurs services orientés événements.

11. Évolutions futures

L'architecture prévoit l'ajout de :

- authentification multifacteur (MFA) ;
- fournisseurs OAuth ;
- authentification sans mot de passe (Passkeys) ;
- authentification biométrique sur mobile ;
- gestion des appareils de confiance.

Ces évolutions n'impliqueront pas de modification des contrats fondamentaux.

12. Documents associés

- 14-VITALA-DOMAIN-MODEL-V1.md
- 15-VITALA-DATABASE-V1.md

- 18-VITALA-ARCHITECTURE-V1.md
- 19-VITALA-MVP-V1.md

L'Auth API constitue la porte d'entrée sécurisée de la plateforme. Elle fournit une identité authentifiée aux autres domaines sans jamais porter la responsabilité des données métier ou de l'Unified Digital Identity.